

Experiment No. 2

Aim:

Exercise on threat modelling

Theory:

Threat modelling works to identify, communicate, and understand threats and mitigations within the context of protecting something of value.

A threat model is a structured representation of all the information that affects the security of an application. In essence, it is a view of the application and its environment through the lens of security.

Threat modelling can be applied to a wide range of things, including software, applications, systems, networks, distributed systems, Internet of Things (IoT) devices, and business processes.

There are five major threat modelling steps:

- Defining security requirements.
- Creating an application diagram.
- Identifying threats.
- Mitigating threats.
- Validating that threats have been mitigated.

Threat modeling is a process for capturing, organizing, and analyzing all of this information. Applied to software, it enables informed decision-making about application security risks. In addition to producing a model, typical threat modeling efforts also produce a prioritized list of security improvements to the concept, requirements, design, or implementation of an application.

In 2020 a group of threat modeling practitioners, researchers and authors got together to write the Threat Modeling Manifesto in order to “...share a distilled version of our collective threat modeling knowledge in a way that should inform, educate, and inspire other practitioners to adopt threat modeling as well as improve security and privacy during development”.

The Manifesto contains values and principles connected to the practice and adoption of Threat Modeling, as well as identified patterns and anti-patterns to facilitate it.

Section 43 - Applicable to people who damage the computer systems without permission from the owner. The owner can fully claim compensation for the entire damage in such cases. **Section 66** - Applicable in case a person is found to dishonestly or fraudulently commit any act referred to in section 43. The imprisonment term in such instances can mount up to three years or a fine of up to Rs. 5 lakh.

Section 66B - Incorporates the punishments for fraudulently receiving stolen communication devices or computers, which confirms a probable three years imprisonment. This term can also be topped by a Rs. 1 lakh fine, depending upon the severity.

Section 66C - This section scrutinizes the identity thefts related to imposter digital signatures, hacking passwords, or other distinctive identification features. If proven guilty, imprisonment of three years might also be backed by a Rs.1 lakh fine.

Section 66 D - This section was inserted on-demand, focusing on punishing cheaters doing impersonation using computer resources.

1. Indian Penal Code (IPC) 1980

Identity thefts and associated cyber frauds are embodied in the Indian Penal Code (IPC), 1860 - invoked along with the Information Technology Act of 2000. The primary relevant section of the IPC covers cyber frauds:

- Forgery (Section 464)
- Forgery pre-planned for cheating (Section 468)
- False documentation (Section 465)
- Presenting a forged document as genuine (Section 471)
- Reputation damage (Section 469)

2. Companies Act of 2013

The corporate stakeholders refer to the Companies Act of 2013 as the legal obligation necessary for the refinement of daily operations. The directives of this Act cement all the required techno-legal compliances, putting the less compliant companies in a legal fix.

The Companies Act 2013 vested powers in the hands of the SFIO (Serious Frauds Investigation Office) to prosecute Indian companies and their directors. Also, post the notification of the Companies Inspection, Investment, and Inquiry Rules, 2014, SFIOs have become even more proactive and stern in this regard. The legislature ensured that all the regulatory compliances are well-covered, including cyber forensics, e-discovery, and cybersecurity diligence. The Companies (Management and Administration) Rules, 2014 prescribes strict guidelines confirming the cybersecurity obligations and responsibilities of the company directors and leaders.

3. NIST Compliance

The Cybersecurity Framework (NCFS), authorized by the National Institute of Standards and Technology (NIST), offers a harmonized approach to cybersecurity as the most reliable global certifying body.

NIST Cybersecurity Framework encompasses all required guidelines, standards, and best practices to manage the cyber-related risks responsibly. This framework prioritizes flexibility and cost-effectiveness. It promotes the resilience and protection of critical infrastructure by:

- Allowing better interpretation, management, and reduction of cybersecurity risks – to mitigate data loss, data misuse, and the subsequent restoration costs.
- Determining the most important activities and critical operations - to focus on securing them Demonstrates the trust-worthiness of organizations that secure critical assets
- Helps to prioritize investments to maximize the cybersecurity ROI
- Addresses regulatory and contractual obligations
- Supports the wider information security program

By combining the NIST CSF framework with ISO/IEC 27001 - cyber security risk management becomes simplified. It also makes communication easier throughout the organization and across the supply chains via common cybersecurity directives laid by NIST.

Security Standards:

To make cybersecurity measures explicit, the written norms are required. These norms are known as cybersecurity standards: the generic sets of prescriptions for an ideal execution of certain measures. The standards may involve methods, guidelines, reference frameworks, etc. It ensures efficiency of security, facilitates integration and interoperability, enables meaningful comparison of measures, reduces complexity, and provide the structure for new developments.

1. ISO

ISO 27000 Series

It is the family of information security standards which is developed by the International Organization for Standardization and the International Electrotechnical Commission to provide a globally recognized framework for best information security management. It helps the organization to keep their information assets secure such as employee details, financial information, and intellectual property.

The need of ISO 27000 series arises because of the risk of cyber-attacks which the organization face. The cyber-attacks are growing day by day making hackers a constant threat to any industry that uses technology. The ISO 27000 series can be categorized into many types. They are

ISO 27001- This standard allows us to prove the clients and stakeholders of any organization to managing the best security of their confidential data and information. This standard involves a process-based approach for establishing, implementing, operating, monitoring, maintaining, and improving our ISMS.

ISO 27000- This standard provides an explanation of terminologies used in ISO 27001.

ISO 27002- This standard provides guidelines for organizational information security standards and information security management practices. It includes the selection, implementation, operating and management of controls taking into consideration the organization's information security risk environment(s).

ISO 27005- This standard supports the general concepts specified in 27001. It is designed to provide the guidelines for implementation of information security based on a risk management approach. To completely understand the ISO/IEC 27005, the knowledge of the concepts, models, processes, and terminologies described in ISO/IEC 27001 and ISO/IEC 27002 is required. This standard is capable for all kind of organizations such as non-government organization, government agencies, and commercial enterprises.

ISO 27032- It is the international Standard which focuses explicitly on cybersecurity. This Standard includes guidelines for protecting the information beyond the borders of an organization such as in collaborations, partnerships or other information sharing arrangements with clients and suppliers.

2. IT Act

The Information Technology Act also known as ITA-2000, or the IT Act main aims is to provide the legal infrastructure in India which deal with cybercrime and e-commerce. The IT Act is based on the United Nations Model Law on E-Commerce 1996 recommended by the General Assembly of United Nations. This act is also used to check misuse of cyber network and computer in India. It was officially passed in 2000 and amended in 2008. It has been designed to give the boost to electronic commerce, e-transactions and related activities associated with commerce and trade. It also facilitate electronic governance by means of reliable electronic records.

IT Act 2000 has 13 chapters, 94 sections and 4 schedules. The first 14 sections concerning digital signatures and other sections deal with the certifying authorities who are licenced to issue digital signature certificates, sections 43 to 47 provides penalties and compensation, section 48 to 64 deal with appeal to high court, sections 65 to 79 deal with offences, and the remaining section 80 to 94 deal with miscellaneous of the act.

3. Copyright Act

The Copyright Act 1957 amended by the Copyright Amendment Act 2012 governs the subject of copyright law in India. This Act is applicable from 21 January 1958. Copyright is a legal term which describes the ownership of control of the rights to the authors of "original works of authorship" that are fixed in a tangible form of expression. An original work of authorship is a distribution of certain works of creative expression including books, video, movies, music, and computer programs. The copyright law has been enacted to balance the use and reuse of creative works against the desire of the creators of art, literature, music and monetize their work by controlling who can make and sell copies of the work.

The copyright act covers the following-

- Rights of copyright owners
- Works eligible for protection
- Duration of copyright
- Who can claim copyright

The copyright act does not covers the following-

- Ideas, procedures, methods, processes, concepts, systems, principles, or discoveries
- Works that are not fixed in a tangible form (such as a choreographic work that has not been notated or recorded or an improvisational speech that has not been written down)

- Familiar symbols or designs
- Titles, names, short phrases, and slogans
- Mere variations of typographic ornamentation, lettering, or coloring

4. Patent Law

Patent law is a law that deals with new inventions. Traditional patent law protect tangible scientific inventions, such as circuit boards, heating coils, car engines, or zippers. As time increases patent law have been used to protect a broader variety of inventions such as business practices, coding algorithms, or genetically modified organisms. It is the right to exclude others from making, using, selling, importing, inducing others to infringe, and offering a product specially adapted for practice of the patent.

In general, a patent is a right that can be granted if an invention is:

- Not a natural object or process
- New
- Useful
- Not obvious.

5. IPR

Intellectual property rights is a right that allows creators, or owners of patents, trademarks or copyrighted works to benefit from their own plans, ideas, or other intangible assets or investment in a creation. These IPR rights are outlined in the Article 27 of the Universal Declaration of Human Rights. It provides for the right to benefit from the protection of moral and material interests resulting from authorship of scientific, literary or artistic productions. These property rights allow the holder to exercise a monopoly on the use of the item for a specified period.

Information Technology Act, 2000

Information Technology (Certifying Authority) Rules, 2000

Information Technology (Security Procedure) Rules, 2004

Information Technology (Certifying Authority) Regulations, 2001

The IT Act is the key to guide the entire Indian law to strictly control cyber crimes (MEIT, 2000).

Section 43 – (damage to computer, computer system, etc.) applies to those who cause damage to computer system without the permission of the owner. In such cases the owner can claim compensation for the full loss.

Section 43A – (Corporate failure to protect data)

Section 44(a) – (failure to produce document, return or report to the controlling or certifying authority)

Section 44(b) – (Failure to file any return or to produce any information, books or other document within specified time)

Section 44(c) – (failure to maintain books of account or records)

Section 45 – (Where no separate punishment has been awarded)

Section 46 – (tampering with computer source documents)

Section 66 – Applicable in the case of any person referred to in section 43 dishonestly or fraudulently committing any act. In such cases the term of imprisonment may extend to three years or with fine which may extend to Rs. 5 lakhs.

Section 66A – Hacking with computer system, alteration of data etc.

Section 66B – Involves punishment for fraudulently obtaining stolen communication equipment or computers, which carries a sentence of imprisonment for a term which may extend to three years. This term can also be extended above Rs. 1 lakh fine depending on the severity.

Section 66C – This section investigates identity theft involving forged digital signatures, hacking passwords, or other unique identification features. to be proven guilty shall be punished with imprisonment of either description for a term which may extend to three years and shall also be liable to fine of one lakh rupees.

Section 66D – This section was inserted on-demand, with a focus on punishing fraudsters who impersonate by using computer resources.

Section 66E – Publishing obscene images

Section 66F – Cyber terrorism

Section 67 – Publishes or transmits unsolicited material

Section 67A – Publishes or transmits explicit sex

Section 67B – abusing children online

Section 67C – Protection of information by arbitrator

Section 70 – Unauthorized access to protected system

Section 71 – Misrepresentation to Controller or Certifying Authority for obtaining license or electronic signature certificate

Section 72 – Violation of confidentiality and confidentiality

Section 73 and 74 – Publishing false digital signature certificates

Conclusion:

Hence, we learn different laws and standards for cyber security.